

İSTANBUL DENEYAP TEKNOLOJİ ATÖLYESİ

Ders Saatleri : 09.00 - 13.00 - Orta Sabah Grubu (Sınıfta) - (29 Haziran-8 Temmuz Hafta İçi)

Ders Saatleri : 13.30 - 17.30 - Orta Öğle Grubu (Sınıfta) - (29 Haziran-8 Temmuz Hafta İçi)



SİBER GÜVENLİK DERSİ

6.Ders: Siber Saldırı Analizi



T3 DENEYAP EĞİTMENİ (Hazırlayan ve Sunan): Muhammed Emin Korkunç

(Bilgiyar Mühendisi)

Bu sunumun kopyalanması, paylaşılması ve yazılı izinsiz kullanımı KESİNLİKLE YASAKTIR.

Muhammed Emin Korkunç | muhammedemin.korkunc@gmail.com | linkedin.com/in/muhammed-emin-korkunc-100ba2215 | github.com/muhammedkorkunc

Sabah Grubu

- 09.00 - 09.50: 1. Ders
- 09.50 - 10.00: 1. Mola
- 10.00 - 10.50: 2. Ders
- 10.50 - 11.00: 2. Mola
- 11.00 - 11.50: 3. Ders
- 11.50 - 12.00: 3. Mola
- 12.00 - 13.00: 4. Ders

Öğle Grubu

- 13.30 - 14.20: 1. Ders
- 14.20 - 14.30: 1. Mola
- 14.30 - 15.20: 2. Ders
- 15.20 - 15.30: 2. Mola
- 15.30 - 16.20: 3. Ders
- 16.20 - 16.30: 3. Mola
- 16.30 - 17.30: 4. Ders



1- Giriş & Tanışma

Siber Saldırı Analizi

Alt Başlık: Güvenlik Dünyasına Giriş ve Temel Kavramlar

- Bugün Ne Öğreneceğiz?
 -  Günlük yaşamdan dijital dünyaya güvenlik algısı
 -  Yazılım ve donanım güvenlik açıkları (Zafiyetler)
 -  İstismar (Exploit) kavramı ve Kali Linux laboratuvarı
 -  Siber sızma yöntemleri (Sosyal Mühendislik, Kimlik Avı)

Bu hafta siber güvenlik dünyasının en kritik konularından birine, yani siber saldırıların anatomisine adım atıyoruz. Saldırılardan korunmanın ilk yolu, saldırganların sistemleri nasıl analiz ettiğini anlamaktır. Hazırsanız günlük hayatımızdan bir beyin fırtınasıyla başlayalım!"

Başlık: Gerçek Hayatta Güvenlik Nasıl Sağlanır?

-  Okula veya apartmanınıza girerken neden anahtar ya da şifreli kart kullanırsınız?
-  Sitenizde veya okulunuzda güvenlik personeli olmasının amacı nedir?
-  Sokaklardaki ve binalardaki güvenlik kameraları nerede ve nasıl işimize yarar?
-  Sonuç: Fiziksel dünyada kapıları kilitlemezsek veya önlem almazsak ne olur?

Günlük hayatta evimizi kilitleriz, kameralar takarız çünkü değerli eşyalarımızı korumak isteriz. Eğer kapıyı açık bırakırsak bu bir 'fiziksel güvenlik açığı' olur. Peki aynı mantık bilgisayarlarımız ve dijital dünyamız için de geçerli mi? Şimdi dijital dünyaya geçelim.



Dijital Dünyada Güvende Miyiz?

-  Bilgisayarınızın ve telefonunuzun güvenliğini nasıl sağlıyorsunuz?
-  Cihazlarınıza parola koymanızın temel amacı nedir?
-  Bir web sitesine üye olurken şifrenizi neye göre belirliyorsunuz?
-  Kritik Soru: Parolanız başka birinin eline geçerse hayatınızda neler değişir?
-  Siber Savaş: Dijital dünyadaki bir açık, devletler arası bir savaşa dönüşebilir mi?

Dijital dünyada şifrelerimiz bizim dijital anahtarlarımızdır. İnternetteki hesaplarımız, kişisel verilerimiz ve fotoğraflarımız bu anahtarların arkasında saklanır. TÜBİTAK BİLGEM'in Parola Güvenliği Ölçer platformunu kullanarak şifrelerimizin ne kadar güçlü olduğunu test edebiliriz.

<https://password.kaspersky.com/tr/>

4- Güvenlik Açığı (Zafiyet) Nedir?



Güvenlik Açığı (Vulnerability)

-  Tanım: Bir bilişim sisteminde, kodlama hatasından veya tasarım eksikliğinden kaynaklanan her türlü "zayıflık" veya "boşluk"tur.
-  Siber saldırganlar sistemlere sızmak için önce bu açıkları arar ve tespit eder.
-  Güvenlik açıkları temelde ikiye ayrılır:
 1. Yazılım Güvenlik Açıkları 
 2. Donanım Güvenlik Açıkları 

Siber güvenlikte biz buna 'Zafiyet' veya 'Vulnerability' diyoruz. Sistemdeki bir kapının kilidinin bozuk olması veya pencerenin açık unutulması gibi düşünebilirsiniz. Saldırganlar sistemlere girmek için her zaman en zayıf halkayı ararlar.

Açık Türleri ve Güncellemelerin Önemi

-  **Yazılım Güvenlik Açığı:** Kod yazılırken yapılan hatalardan veya mantık açıklarından oluşur.
 -  **Çözüm:** Üreticiler bu hataları kapatmak için Yama (Patch) veya Güncelleme yayınlar. Telefon ve bilgisayarları güncel tutmak bu yüzden hayatidir!
-  **Donanım Güvenlik Açığı:** Doğrudan fiziksel parçaların (örneğin işlemcilerin) tasarım aşamasındaki hatalardır.
 -  **Örnek:** İşlemcinin (CPU) performans artsın diye komutları sıra gözetmeden çalıştırması (Öngörülü Yürütme) büyük zafiyetler doğurabilir.
 -  **Araştırma Ödevi:** Dünyayı sallayan Meltdown ve Spectre donanım açıklarını duydunuz mu?

Yazılım açıkları kolayca güncellemeye kapatılabilirken, donanım açıkları fabrikada üretilen çiple ilgili olduğu için çözülmesi çok daha zordur. Google güvenlik uzmanlarının Intel, AMD ve ARM işlemcilerde bulduğu Meltdown ve Spectre, donanım açıklarının en büyük örneklerindendir.

6- İstismar (Exploit) Nedir?

İstismar (Exploit) Kavramı

-  **Exploit Nedir? Sistemdeki bir güvenlik açığını (zafiyeti) kullanarak sisteme sızmayı, zarar vermeyi veya yetki ele geçirmeyi sağlayan özel kod blokları veya programlardır.  Süreç Nasıl İşler? Güvenlik Açığı (Açık Kapı) → Exploit Yazılması (Kapıdan Sızma Aracı) → Sistemin Ele Geçirilmesi**
-  **Kali Linux içerisinde binlerce hazır exploit barındıran Exploit Database (exploitdb) isimli bir kütüphane bulunur.**

Özetle; güvenlik açığı sistemdeki kilitli olmayan bir pencereyse, exploit de o pencereden içeri sızmak için saldırganın kullandığı merdivendir. Şimdi Kali Linux terminalimizi açıp, bu sızma araçlarının (exploit kodlarının) yapısını yakından inceleyeceğiz.



Kali Linux ile Exploit Dünyasına Bakış

-  Adım 1: root yetkisiyle terminali aç.
-  Adım 2: Exploit kütüphanesine git:
`cd /usr/share/exploitdb/`
-  Adım 3: Windows platformundaki uzaktan sızma (remote) araçlarını bul ve bir exploiti masaüstüne kopyala:
`cp platforms/windows/remote/5751.pl /root/freeSSHdexploit.pl`
-  Adım 4: Kodun içine bak ve siber saldırganların mantığını analiz et:
`vim /root/freeSSHdexploit.pl`

Bu uygulamada amacımız bir sistemi hacklemek değil, bir exploitin kod yapısını incelemek. Bu sayede bir siber saldırganın zafiyetleri sömürmek için ne tür script dilleri (örneğin Perl veya Python) kullandığını görmüş oluyoruz





Yaygın Zafiyet Çeşitleri

-  **Arabellek Taşması (Buffer Overflow):** Bir uygulamanın bellekte kendisine ayrılan sınırların dışına taşarak sistemi çökertmesi veya yetkisiz kod çalıştırması.
-  **Doğrulanmamış Girdi (Unvalidated Input):** Kullanıcıdan alınan verilerin kontrol edilmeden sisteme kabul edilmesi (Örn: Giriş ekranına şifre yerine zararlı kod yazılması).
-  **Güvenlik Zayıflıkları:** Test edilmemiş, güvensiz kod kütüphanelerinin kullanılması.
-  **Erişim Sorunları:** İçerideki kullanıcıların doğru izlenmemesi (Unutmayın: Siber risklerin büyük kısmı içerideki kullanıcıların hatalarından kaynaklanır!).
-  **Araştırma Ödevi:** Tarihteki ünlü Morris Worm ve SQL Slammer saldırılarını araştırın!

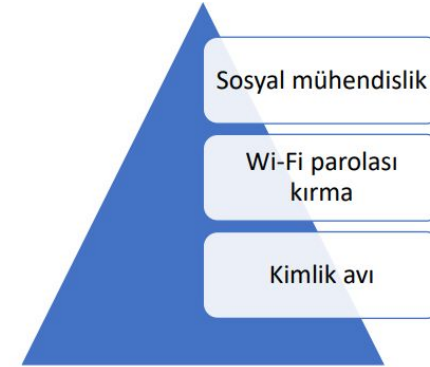
Yazılımlarda girdi kontrolü çok önemlidir. Eğer bir web sitesinin arama çubuğuna sadece kelime yazılması gerekirken siber saldırgan oraya bir kod yazar ve sistem de bunu çalıştırırsa, bu 'doğrulanmamış girdi' zafiyetidir."





Güvenlik İhlali Yöntemleri

- **Sosyal Mühendislik (Social Engineering):** Sistemleri değil, insan psikolojisini hackleme sanatıdır!
 - İnsanların merak, korku, heyecan veya dikkatsizliklerinden yararlanarak onları tuzağa düşürme işlemidir.
- **Kimlik Avı (Phishing / Oltalama):** En yaygın sosyal mühendislik yöntemidir.
 - Güvenilir bir kurumdan (Banka, Netflix, e-Devlet, Telekom) geliyormuş gibi sahte e-posta veya SMS atarak kurbanın şifrelerini çalmayı hedefler.
- **Wi-Fi Parolası Kırma:** Kablosuz ağ şifrelerini kaba kuvvet (Brute Force) veya sosyal mühendislik yöntemleriyle ele geçirme saldırısıdır.



Şekil 1. Güvenlik ihlali yöntemleri

Dünyanın en güçlü güvenlik duvarını da kursanız, içerideki bir çalışan 'Şifrenizin süresi doldu, yenilemek için tıklayın' diyen sahte bir e-postaya inanıp şifresini yazarsa sistem çöker. İşte siber saldırganların en çok sevdiği yöntem budur: İnsanın dikkatsizliğini kullanmak.



Güvenlik Zincirinin En Zayıf Halkası Kim?

-  Güvenlik sadece teknik bir konu değil, bir farkındalık meselesidir.
-  Teknoloji ne kadar gelişirse gelişsin, insan eğitimi olmadan siber güvenlik tam sağlanamaz.
-  Sizce: Bir şirketi korumak için milyon liralık yazılımlar mı daha önemlidir, yoksa çalışanların siber güvenlik eğitimi alması mı?

Sızma yöntemlerini ve güvenlik açıklarını gördük. Unutmayın, güvenlik zinciri en zayıf halkası kadar güçlüdür ve siber dünyada en zayıf halka genellikle insandır. Şimdi bir sonraki konumuz olan '1.3 Saldırılar' başlığı ile siber saldırganların bu açıkları kullanarak sistemleri nasıl çalışamaz hale getirdiğine (DoS/DDoS) bakacağız!

Saldırılar ve Sınıflandırma

-  **Siber saldırılar hedeflerine göre temelde 3 ana gruba ayrılır:**
 1. **Ağ Saldırıları**  (Veri trafiğini ve kablolu/kablosuz iletişim hatlarını hedef alır)
 2. **Sistem Saldırıları**  (İşletim sistemlerini ve sunucu altyapılarını hedef alır)
 3. **Web Saldırıları**  (Web sitelerini ve internet uygulamalarını hedef alır)
-  **Günümüzde en sık karşılaşılan ve servisleri felç eden ağ saldırılarının başında DoS ve DDoS gelir.**

Siber saldırganlar amaçlarına ulaşmak için farklı kulvarları kullanırlar. Bir web sitesinin açığından sızmakla, o web sitesinin bağlı olduğu internet hattını kilitlemek farklı şeylerdir. Şimdi internet hatlarını ve servisleri tamamen çökerten DoS ve DDoS mantığını inceleyelim.



Ağ Trafiği İzleme Uygulaması

- 👁️ **Wireshark Nedir?** Ağ kartımızdan geçen tüm dijital paketleri yakalayan, analiz eden ve ağda neler döndüğünü görmemizi sağlayan en popüler siber güvenlik aracıdır.
- 🔧 **Kali Linux ile Uygulama Adımları:**
 1. Terminali açın ve wireshark yazıp enter'a basın.
 2. Aktif internet kartınız olan eth0 arabirimine çift tıklayarak dinlemeyi başlatın.
 3. Yan tarafta yeni bir terminal açıp ping 8.8.8.8 komutuyla Google sunucularına paket gönderin.
 4. Wireshark ekranında akan ICMP paketlerini izleyin!

Ağ yöneticileri ve siber güvenlik uzmanları, görünmeyen dijital dünyayı görebilmek için Wireshark kullanırlar. Tıpkı bir doktorun röntgen çekmesi gibi, biz de ağın röntgenini çekiyoruz. Bir web sitesine girdiğinizde arka planda yüzlerce DNS, TCP ve HTTP paketinin nasıl uçtuğunu buradan canlı görebilirsiniz.





Protokolleri ve Web İsteklerini Yakalamak

-  Terminale **firefox** yazarak tarayıcıyı açın.
-  Adres satırına **http://www.gazi.edu.tr** yazıp sayfayı yükleyin ve ardından tarayıcıyı kapatın.
-  **Wireshark Ekranını İnceleyin:**
 - Sayfa açılırken arka planda çalışan **DNS (İsim Çözümleme)** paketlerini bulun.
 - Veri iletimini sağlayan **TCP ve HTTP** paketlerini yakalayın.
 - Sağ kısımdaki açıklamada **"200 OK"** ifadesini görüyorsanız, web sayfasının başarıyla bilgisayarımıza ulaştığını anlarız.

Web sitesine tıkladığımız an Wireshark'ta devasa bir hareketlilik oldu. Bilgisayarımız Gazi Üniversitesi sunucusuna 'Bana ana sayfayı gönder' dedi, sunucu da '200 OK' yani 'İsteğinizi aldım, her şey yolunda, verileri gönderiyorum' yanıtını verdi. Siber dünyada her iletişimin bir kodu vardır.



DoS ve DDoS Arasındaki Fark Nedir?

-  **DoS (Denial of Service):** Tek bir kaynaktan (tek bir bilgisayar veya IP) hedef sunucuya aşırı miktarda sahte veri gönderilmesidir. Sunucu aşırı yükten dolayı kilitlenir ve hizmet veremez hale gelir.
-  **DDoS (Distributed DoS):** Saldırının tek bir merkezden değil, dünya genelinde binlerce "Zombi Bilgisayar" (Botnet) tarafından aynı anda yapılmasıdır.
-  **Tarihi Vaka:** 28 Şubat 2018'de GitHub'a tam 1.35 Tbps büyüklüğünde devasa bir DDoS saldırısı yapıldı ve tarihe geçti!

DoS saldırısını, bir mağaza kapısına tek bir kişinin sürekli girip çıkarak gerçek müşterileri engellemesine benzetebiliriz. DDoS ise, saldırganın kandırdığı veya virüs bulaştırdığı binlerce 'zombi' insanı aynı anda o mağazanın kapısına yığmasıdır. Bu kadar büyük bir kalabalığa karşı tek bir sunucunun dayanması imkansızdır

Monitör ve Managed Modları

iwconfig = yazınca kablosuz bağlantımızın detayı bilgileri gelir mode yazan yerde managed veya monitor yazar. Monitor modda bağlı olmadığımız ağlar hakkında bilgi toplayabiliyoruz.

Managed modda internete bağlanabiliyoruz.

airmon-ng = bir araç

airmon-ng check kill = şuanda monitor moda Geçmeyi engelleyen tüm çalışan araçları kapatır.

airmon-ng start wlan0 = monitor moda geçmemizi sağlar

iwconfig = mode monitor olduysa işlem başarılı olmuş demektir

airmon-ng stop wlan0 =monitor modu kapatır managed moda döner

Ağları İncelemek

airmon-ng start wlan0 =monitor mode açılır

airodump-ng wlan0 = wifi card etraftaki kablosuz ağları ve yayınları gösteriyor

BSSID = Modemin Mac adresi

PWR = -1 en yakın modem sayı büyüdükçe uzaklaşıyor

ESSID = modemin ismi

BEACONS VE DATA = Bağlı cihaz sayısı ve kaç verinin gidip geldiğini gösteriyor

CH = Modemin hangi kanalda kullanıldığını gösteriyor

ENC = şifreleme ismi

DEAUTH SALDIRISI

airodump-ng —channel 5(seçilen modemin channelı) —bssid 00:00:11:11:00:00(bssid yerine yazan numara) wlan0 = bir ağ seçeriz ve bilgilerini toplarız

aireplay-ng --deauth 10000 -a 10:20:30:40 wlan0 =. deauth saldırı büyüklüğü ve -a access point erişim noktası yani modemin Mac adresini ifade eder. Bu komple ağdaki herkesi düşürür

aireplay-ng --deauth 10000 -a 10:20:30:40 -c 00:00:11:11:00:00 (seçilen Mac adresi) wlan0 = belli bir Mac adresine saldırı



Araştırma Konumuz: Ağ Trafiğini Manipüle Eden Saldırılar

- 👤 **Man-in-the-Middle (MitM) - Aradaki Adam:** Saldırganın, iki cihaz arasındaki veri trafiğinin arasına gizlice girerek verileri gizlice dinlemesi veya değiştirmesidir.
- 💉 **ARP Poisoning (ARP Zehirlenmesi):** Yerel ağdaki IP adresleri ile MAC adreslerini eşleştiren tabloyu sahte verilerle manipüle ederek trafiği kendi üzerine çekme saldırısıdır.
- 🌐 **DNS Spoofing (Önbellek Zehirlenmesi):** İnternet adreslerinin yönlendirildiği rehberi (DNS) hackleyerek, kullanıcıları gitmek istedikleri site yerine sahte/zararlı sitelere yönlendirmektir.
- 🔌 **Port Çalma (Port Stealing):** Ağ anahtarlama cihazlarını (Switch) kandırarak başka bir bilgisayara giden paketleri çalma yöntemidir.
- 🌳 **STP Mangling:** Ağdaki yedekli yolları yöneten STP protokolünü bozarak ağ trafiğinde

Göreceksiniz ki bu saldırıların neredeyse tamamı, bilgisayarların birbirine güvenerek gönderdiği ağ mesajlarını taklit etmek ve kandırmak üzerine kuruludur.



Beyaz Şapkalı Hacker Cihaz Çantası

-  **Nmap / Zenmap:** Ağ tarama ve port keşif aracı.
-  **Metasploit:** Güvenlik açıklarını test etme ve istismar (exploit) platformu.
-  **SQLMap:** Veritabanı güvenlik açıklarını tespit etme aracı.
-  **Wireshark:** Ağ paket analizi ve trafik dinleme yazılımı.
-  **Nikto / OpenVAS:** Web sitesi ve sistem zafiyet tarayıcıları.
-  **Maltego:** Açık kaynak istihbarat ve bilgi toplama aracı.

Burada gördüğünüz araçlar çift taraflı bıçak gibidir. Beyaz şapkalı bir hacker bunları sistemleri korumak ve açıkları kapatmak için kullanırken, siyah şapkalı bir hacker zarar vermek için kullanır. Bizler her zaman savunma ve güvenlik tarafındayız!



Dijital Kimlik Kontrolü

-  **WHOIS Nedir?** İnternetteki bir web sitesinin (alan adının) kime ait olduğunu, hangi firma üzerinden ne zaman satın alındığını gösteren dijital tapu sorgulama sistemidir. <https://www.whois.com/>

Uygulama Adımları:

1. Tarayıcınızdan bir WHOIS sorgu sitesine girin (Örn: Turhost).
2. Arama kutusuna örnek bir alan adı yazın (Örn: celebiuluyol.com).
3. Alan adının Oluşturulma Tarihi, Bitiş Tarihi ve Kayıt Firması bilgilerini raporlayın.

Bir siber saldırgan veya güvenlik uzmanı, hedef hakkında bilgi toplarken ilk olarak WHOIS sorgusu yapar. Bu sayede sitenin sahibine, teknik sorumlusuna ve sitenin ne kadar süredir yayında olduğuna dair kritik ipuçları elde edilir.





Tasarla ve Üret Öncesi En Önemli Hatırlatma!

- **Etik Nedir?** Toplum tarafından kabul edilmiş; iyi, doğru, adalet ve erdem ilkelerini temel alan evrensel değerlerdir.
- **Bilgisayar Etik Enstitüsü Kuralları:**
 - **Bilişim teknolojileri başkalarına zarar vermek veya hırsızlık yapmak için kullanılamaz.**
 - **Başka bir kişiye ait özel veriler ve çalışmalar izinsiz incelenemez/karıştırılmaz.**
 - **Lisanssız, korsan veya kırılmış (crackli) yazılımlar kullanılamaz.**
 - **Unutmayın: Yazdığınız her kodun ve yaptığınız her siber eylemin sonuçlarından yasal olarak sorumlusunuz!**

DDoS simülasyon yarışması yapacağız. Ancak siber güvenlikte güç, büyük bir sorumluluk getirir. Öğrendiğimiz bu teknikleri asla ve asla izin almadığımız gerçek sistemlerde denemiyoruz. Unutmayın, etik kurallara uymayan bir hacker siber kahraman değil, siber suçludur.



DDoS Saldırısı Yarışması

- ⌚ **Süre: 60 Dakika (15 dk Video İzleme + 30 dk Uygulama + 15 dk Sunum & Tartışma)**
- 📺 **Görev 1: Size verilen eğitim videolarını dikkatlice izleyerek bir DDoS aracının laboratuvarında nasıl çalıştığını öğrenin.**
- 💻 **Görev 2: Kendi bilgisayarınızdaki test ortamında en hızlı ve doğru şekilde DDoS simülasyonunu başlatın.**
- 🏁 **Yarışmayı başarıyla tamamlayan ilk grup, sahneye gelerek arkadaşlarına bu saldırıya karşı nasıl önlem alınması gerektiğini sunacaktır!**
- <https://www.youtube.com/watch?v=3uZABZnc2IU>
<https://www.youtube.com/watch?v=p-VnVAZkLvs&t=31s>
<https://www.youtube.com/watch?v=J2rS6gKo95M>

DDoS simülasyonlarımızı başlatacağız. En hızlı yapan grubun sunumunun ardından bu devasa saldırılara karşı dünyadaki büyük şirketlerin nasıl korunduğunu tartışacağız.



Güvenlik Duvarları (Firewall) Yeterli Mi?

-  Firewall (Güvenlik Duvarı): Gelen ve giden ağ trafiğini inceleyerek zararlı paketleri engelleyen yazılım veya donanım sistemleridir.
-  DDoS Karşısındaki Yetersizlik: Standart güvenlik duvarları, milyonlarca farklı zombi bilgisayardan gelen devasa DDoS trafiğini ayırt etmekte ve engellemekte yetersiz kalabilir.
-  Modern Çözümler: DDoS saldırılarına karşı özel trafik temizleme merkezleri (Scrubbing Centers) ve CDN (İçerik Dağıtım Ağları) koruma sistemleri kullanılır.

Şirketler bu saldırılardan nasıl korunuyor? Cevap: Güvenlik Duvarları (Firewall). Ancak binlerce zombi bilgisayar aynı anda saldırdığında standart duvarlar yıkılır. Bu yüzden günümüzde trafiği süzerek sahte istekleri çöpe atan çok daha gelişmiş küresel DDoS koruma sistemleri kullanılmaktadır.



-  Bir kurumun Bilgi İşlem (IT) Birimi sizce ne iş yapar?
-  Bilgi işlem yetkilileri kurum ağını neden 7/24 izlemek zorundadır? İzlemezlerse ne olur?
-  Yakın zamanda duyduğunuz küresel veya yerel bir siber saldırı vakası var mı?
-  Vaka Analizi: 2021 yılı Mart ayında Yemeksepeti firmasına yapılan ve milyonlarca kullanıcının verilerinin sızdırıldığı siber saldırıyı duymuş muydunuz?

Evet arkadaşlar, bu haftaki siber saldırı analizimizin sonuna geldik. Gördüğünüz gibi büyük şirketler bile (Yemeksepeti örneğinde olduğu gibi) bazen siber saldırıların kurbanı olabiliyor. Bu yüzden ağ analizi yapmak ve trafiği sürekli izlemek lüks değil, zorunluluktur





Sistemlerin Açık Kapılarını Keşfetmek

- Port Tarama Nedir? Bir sunucuda hangi servislerin (Web, E-posta, SSH vb.) dış dünyaya açık ve erişilebilir olduğunu bulma işlemidir.

Son olarak ek etkinliğimiz olan Zenmap aracını inceliyoruz. Unutmayın, bir eve sızmak isteyen hırsız önce açık pencere arar. Siber dünyada da 'Portlar' sistemin pencereleridir. Zenmap ile hedef sistemin hangi pencerelerinin açık (yeşil) olduğunu tarayarak siber durum tespiti yapabiliyoruz. Harika bir ders oldu, haftaya görüşmek üzere!

1. Kali Linux terminal içinde zenmap yazıp enter tuşuna basarak programı çalıştır.
2. Program ekranında target (hedef) kısmına IP adresi yazmak gereklidir. Hangi IP adresinin çalışıp çalışmadığını terminal ekranından ping atarak öğrenebilirsiniz. Örneğin ping celebiuluyol.com yazdığınızda cevap geliyorsa o web sitesi çalışır durumda ve size yanıt veriyordur.
3. Ping attığınızda ilgili sitenin IP adresi terminal ekranında çıkacaktır. Oradan kopyala yaparak program içerisinde target kısmına yapıştırın.
4. IP adresini yapıştırdıktan sonra hemen sağ tarafta "profile" aşağı açılır kutusu görünecektir. Bu kısım taramanın nasıl olacağı ile ilgilidir. Tüm TCP portlarını tara, akıllı tarama, hızlı tarama vb. seçenekler burada mevcuttur. Quick scan hızlı tarama seçeneğini seçin.
5. Scan düğmesine tıklayın. 6. Tarama işlemi için kısa bir süre bekleyin.
7. Ekranda arama sonucunda taranan portlara ilişkin çeşitli bilgiler yer almaktadır. Ekranda gördüğünüz yeşil portlar o portun aktif, sarılar ise aktif olmadığını göstermektedir.
8. İlgili ekranda port sütununda port numaraları, state sütununda açık veya filtreli kapalı olma durumları, service sütununda ise ftp, domain, http, pop3 vb. gibi hizmetin adı görülmektedir.
9. Ports/hosts düğmesine tıklayın. Ekranda açık ve kapalı portlar listelenecektir. Herhangi bir sızma girişiminde bulunmak istenen bilgisayara ait bu bilgilerin önceden bilinmesinde veya kontrol edilmesinde yarar vardır.
10. Host details düğmesine tıklandığında ise bu sunucuya ait portlarla ilgili istatistiksel bilgiler görülebilir, örneğin toplam kaç portun açık veya kaç tanesinin kapalı olduğu gibi. 11. Detaylı incelemelerin ardından programı kapatabilirsiniz.



